



电力物联网的访问控制 关键技术及应用

(清华大学创新领军工程博士学位论文选题报告)

培 养 单 位： 自动化系

领 域： 电子信息

研 究 生： 崔 釜

学 号： 2020319153

指 导 教 师： 李 军 研究员

联合指导教师：

二〇二二年六月

摘要

高速发展的物联网技术深入到生产生活的各处，带来便利的同时，也引发了人们对安全的担忧。大量且持续增加的物联终端，在物联网中生成并传播着海量的数据，也成为了安全和隐私的巨大挑战。物联网中异构的设备、协议与应用加大了安全管理的难度。随着应用场景的日益丰富，对物联网安全防护能力的要求也越来越高。访问控制是应对安全与隐私问题的重要手段之一。在典型的物联网三层架构中，网络层连接感知层与应用层。在网络层实施访问控制能够有效应对物联网所面对的安全挑战。以电力物联网为例，随着新型电力系统的建设，电力物联网由传统的专用、受限网络变得更加开放、复杂。在电力物联网的场景中，访问控制需要更加注重扩展性、动态性与灵活性。本课题以电力物联网为研究对象，拟提出一套网络访问控制模型与机制，在以电力物联网为代表的典型工业物联网应用场景中，提供可扩展的、动态的及灵活的访问控制。本课题拟研究三个关键问题，分别是：基于设备画像的访问控制模型，云边协同的动态访问控制方法，和基于编排的访问控制技术。传统访问控制基于主体单一的身份表示进行认证、授权。物联网内的终端海量异构，设备的身份缺少一致性，访问控制的策略也随之复杂，安全管理成为巨大挑战。研究基于设备画像的访问控制模型，旨在根据设备静态属性（基本信息，如产品型号、厂商、MAC 地址和 IP 地址等）和动态属性（如访问请求、时间、位置等）的组合，“实时”匹配设备画像取代单一的设备身份，将访问控制策略与设备画像关联而与设备脱钩，实现设备无关的访问控制。传统的“云管边端”的典型架构中，云边通信的防护以安全通道和静态策略相结合的方式为主。一旦边缘环境被突破，攻击者便可畅行无阻。而由于边缘策略更新维护不及时导致的云边不匹配的情况更放大了这一风险。研究云边协同的动态访问控制方法，旨在通过解耦访问控制的决策与执行，以控制平面对访问请求及环境条件等上下文属性动态地评估，以数据平面多个策略执行点协同执行访问控制决策。提升云边通信的安全能力。随着物联网承载业务的增多，多种应用共享网络通道。一方面添加部署相应的访问控制机制成为挑战，另一方面配置了多套的安全装置的场景下，业务（特别是时延敏感涉控业务）性能也常会受到影响。研究基于编排的访问控制技术的主要目的是通过对网包检测能力和处置方法的整理与抽象，构建一系列安全微服务；通过微服务编排应对多样的安全需求。本课题成果拟在电力物联网的场景中进行实际部署应用。在访问控制的统一管理，动态协同执行和灵活处置等方面的创新性有助于在各类典型物联网应用场景中推广使用。

目 录

摘 要	I
目 录	II
第 1 章 选题的背景及意义	1
第 2 章 文献综述	4
2.1 基于属性的访问控制	4
2.2 基于能力的访问控制	5
2.3 软件定义安全	6
2.4 身份	7
2.5 小结	8
第 3 章 研究内容及方案	10
3.1 基于设备画像的访问控制模型	10
3.1.1 问题描述	10
3.1.2 拟采用的方法	10
3.1.3 研究进度及计划	11
3.2 云边协同的动态访问控制方法	12
3.2.1 问题描述	12
3.2.2 拟采用的方法	13
3.2.3 研究进度及计划	15
3.3 基于编排的访问控制技术	15
3.3.1 问题描述	15
3.3.2 拟采用的方法	15
3.3.3 研究进度及计划	17
第 4 章 预期成果及创新点	18
第 5 章 论文工作总体安排	19
参考文献	20

第 1 章 选题的背景及意义

物联网技术高速发展，广泛连接了人们的生产生活。据预测，到 2025 年会有约 270 亿台设备接入物联网^①。物联网在个人消费、商业和工业领域都有多样的应用场景，在电网、交通出行、医疗健康、家庭、教育等各个行业都得到广泛的应用。在带来便利的同时，物联网也引发了人们对安全的担忧：一方面，持续扩充的异构的设备、协议与应用加大了安全管理的难度；另一方面，应用场景的丰富、终端算力的提升愈发吸引攻击者的关注。物联网能够产生并传播大量的数据，也具备控制生产生活中的关键节点的能力。一旦物联网遭受攻击，可能导致机密信息失窃、个人隐私泄露，甚至业务中断，财产损失等后果，严重的还会危害国家安全及个人生命安全。

持续发生的物联网攻击事件，提醒人们要特别重视物联网的安全。通过对攻击事件整理、总结不难发现，针对物联网的攻击通常分为侦察、入侵、传播和攻击等阶段，网络是攻击者最为常利用的攻击介质之一^[1]。近些年爆发的 Mirai、WannaCry 等攻击都与物联网有一定的关联，也都造成了巨大的危害。Mirai 通过入侵物联网设备构建僵尸网络，对网络关键基础设施实施分布式拒绝服务（DDoS, Distributed Denial of Service）攻击。WannaCry 则通过微软 MS17-010 远程代码执行漏洞入侵受影响的 Windows 操作系统，对系统内所有的文件实施加密，勒索文件的所有者，同时造成业务的中断。尽管两种攻击的对象、形式、乃至结果都有差异，但是它们都对受害者造成了重大的损失。此外，两种攻击都能够通过网络实施的入侵、传播和攻击。因此，做好网络访问控制能够极大程度的避免攻击带来的危害。

典型的物联网架构分为感知层、网络层和应用层，每一层面面临的安全威胁不尽相同。受限于环境、功耗、算力等因素，多数物联网设备、协议以及应用在设计之初以功能性、可靠性以及成本效益等因素为重，对安全环节较少涉及^[1]。在感知层和应用层增加安全防控机制，意味着大量的设备、协议和应用可能需要重新设计。在网络层，由于网关等具有安全能力的基础设施存在，具备叠加安全防控手段的能力。同时，在网络层部署的安全设施不仅具备保障数据安全传输的能力，同时也具有一定的设备认证与接入管理能力，一定程度上支持和补充了感知层和应用层的安全缺失。因此，在网络层实施访问控制能够有效的应对物联网所面对的安全挑战。

事实上，针对物联网的网络层访问控制一直倍受重视。以工业物联网（IIoT, Industrial Internet of Things）为例，网络隔离、单向网闸、网络防火墙等方案与技

① 数据来源：<https://iot-analytics.com/number-connected-iiot-devices/>

术都曾发挥巨大的作用。然而随着工业物联网承载的业务越来越多，早期封闭的网络环境越来越开放，对网络质量和安全能力的要求也越来越高。在扩展性、动态性以及灵活性等方面，传统的网络访问控制方案面临了巨大的挑战。电力物联网是工业物联网的代表性应用场景之一。传统上，电力物联网与电网内其它类型的信息网络更加相近，是专用网络、受限网络：数据仅在电网内部流动，且仅有经过严格验证的用户可以访问相关数据及服务^[2]。我国的电网企业一直以“安全分区、网络专用、横向隔离、纵向认证”的“十六字方针”作为网络安全的基本原则^[3]。早期建设的电力物联网的安全防护通过基于边界部署的一系列独立的安全防护装置和静态访问控制规则实现。通过叠加特定功能的安全装置或新的访问控制规则，满足新业务的安全需求（如图1）。

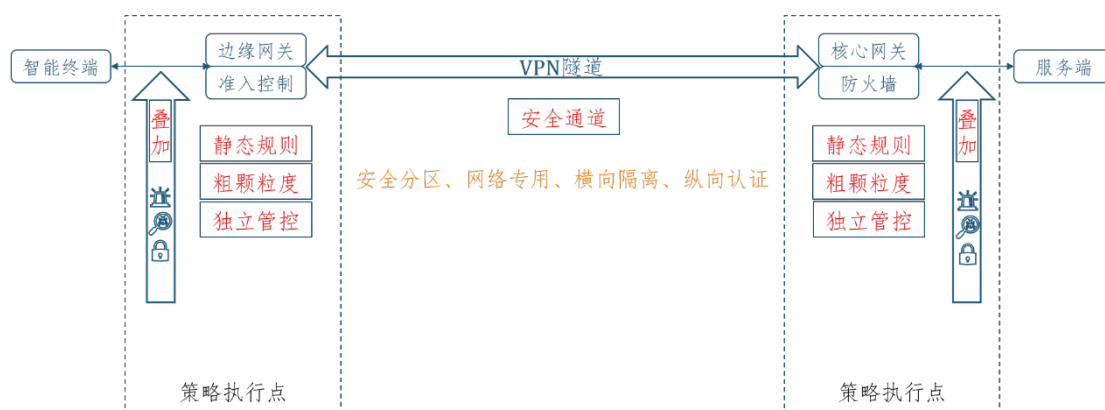


图1. 传统架构下电力物联网的安全模型示意

随着新型电力系统的建设，新能源、新负荷和新业务模式的接入，使得电网公司的业务从原有的“源随荷动”的单一运行模式，转变为“源网荷储”多级协同互动的复杂模式^[4]。大量的社会资源和新业务应用通过网络接入电网系统，打破了“专网专用”的局面。电力物联网的传统安全架构面临了新的挑战：首先，县域分布式光伏等新能源项目推动了海量异构的物联终端接进电力物联网，增大了终端管控难度^[5]；其次，原本工作在电网内部的部分涉敏、涉控业务，随着业务的发展延伸到电网外部，原本基于边界的防御体系难以应对^[6]；第三，以能源交易、无人机巡检、配网智能化等为代表的新业务，要求电力物联网具备处理高并发、大带宽、低时延的网络请求的能力，对原有的网络安全能力也提出新的要求^[7]。

具体来说，终端数量会影响访问控制策略的数量，异构设备则会对策略复杂度造成影响。而策略的数量和复杂度都会影响访问控制的执行效率 and 管理的难度。故而需要研究一套可扩展的访问控制模型以应对海量异构的物联设备的接入带来的挑战。云端与边缘的通信通常采用有线专网、无线专网或虚拟专用网络（VPN，

Virtual Private Network) 等安全通道辅以静态的访问控制策略以保障安全。一旦边缘安全被突破,攻击者就可以从边缘对云端发起攻击。此外,受地理位置,运维人员能力等因素制约,边缘的访问控制策略往往不能及时更新。与云端无法匹配的边缘安全策略更增大了被攻击的风险。因此,有必要研究一种访问控制的动态执行方法以化解传统边界防御的面临的风险。新业务的增加,需要引入新的访问控制策略或者访问控制装置。但前者由于配置复杂(策略庞大)难于执行,后者更会引入整体的停机时间。而在配置了多套的安全装置的场景下,业务性能也常会因为层层检查受到一定影响。因此,有必要研究一种能够灵活配置各种安全能力的访问控制技术以满足不同业务的安全需求从而缓解这一困境。

综上所述,研究物联网的网络访问控制对物联网安全具有重要意义。电力物联网的安全需求与所面对的安全挑战在工业物联网乃至整个物联网领域都具有代表性、典型性。在电力物联网场景中,研究可扩展的、动态的及灵活的网络访问控制,其研究成果不仅有助于电网应对新业务新模式带来的安全挑战,保护电网安全运行,更有助于提升工业物联网的整体安全水平,助力物联网产业快速发展。

第2章 文献综述

访问控制是解决安全问题的基础。通过访问控制，所有未授权的访问企图将被阻断，而经过授权的访问则被允许操作。访问控制的本质是控制何人（主体，Subject）对何物（客体，Object）执行何种操作（访问操作，Action）的一种方法。其中主体、客体和操作构成了访问控制的最基本要素。访问控制规则或策略表述了这些要素间的关系。访问控制模型用以评估访问请求是否符合访问控制策略并做出授权决策。访问控制方法则是模型与策略的实施指导。

2.1 基于属性的访问控制

访问控制自诞生以来，已经广泛应用于各种领域，也产生了多种具有代表性的模型。传统的访问控制模型包括：自主访问控制模型（DAC，Discretionary Access Control），强制访问控制模型（MAC，Mandatory Access Control）以及基于角色的访问控制模型（RBAC，Role Based Access Control）。而基于属性的访问控制模型（ABAC，Attribute Based Access Control）在评估主体、客体和操作的属性的基础上，引入了环境条件等上下文属性，在扩展性、动态性和灵活性上相对传统的访问控制模型都有了巨大的提升，日渐成为主流的访问控制模型。在物联网领域，在比较了多种访问控制模型之后，文献[8]认为由于具有灵活的属性支持，ABAC是最适合物联网的访问控制模型。文献[9]以ABAC为基础，通过四种属性完成了物联终端（传感器和执行器）与底层接入网关的轻量化的动态访问控制。由于物联终端的算力非常有限，这些属性都交由上层网关计算，几乎没有增加物联终端设备的负担。以ABAC的优点为基础，文献[10]提出了一种基于属性的访问与通信控制（ABAC-CC，Attributed Based Access Control and Communication Control）模型。在ABAC-CC模型中，物联网中传输的数据被分为两类，一类是基于请求-响应而传递的数据；一类是设备间主动传递的数据。对请求响应类数据，适用于“传统的”ABAC模型，阻止了非授权访问，保证了数据的机密性；而对于消息传递，文献提出了新的基于属性的通信控制（ABCC，Attributed Based Communication Control）模型，能够细粒度的按需过滤传输数据中的敏感字段，为数据的所有者提供了更多隐私保护的能力。

可扩展的访问控制标记语言（XACML，eXtensible Access Control Markup Language）作为ABAC的事实标准也在物联网领域得以广泛应用^[11]。XACML既是一种描述访问控制策略的语言，同时也是一套访问控制实施框架，能够灵活的支

持不同场景的物联网访问控制需求,文献[12]据此提出了一套基于风险的自适应访问控制模型,展示了 XACML 架构的通用性与灵活性。

ABAC 模型与 XACML 架构的組合的灵活性也带来复杂度的巨大提升。这已经影响了该组合在物联网领域中进一步的应用^[13]。为了避免 XACML 表达策略定义所使用的抽象语言面对的句法和语义的复杂性^[14],美国国家标准与技术研究院(NIST, National Institute of Standards and Technology)提出了基于下一代访问控制(NGAC, Next Generation Access Control)的 ABAC 实现框架。相对于 XACML 使用语义表述策略,NGAC 更注重关系的表达。Bezawada B 等^[11]以智能家庭为研究对象,使用 NGAC 框架,实现了基于 ABAC 的应用于智能家庭的访问控制。作者通过 NGAC 预置了大量预定的访问控制策略,用户也可以使用接近自然语言的方式来自定义访问控制策略。关系的定义使得在 NGAC 框架下的访问控制策略更加的直观并且易于管理。NGAC 定义了四种关系来表达策略,包括指派(Assignment),关联(Association),禁止(Prohibition),职责(Obligation)。其中 Assignment 是用来表述用户或者客体与属性的关系,Association 和 Prohibition 是表述主体(属性)与客体(属性)之间的某种操作(比如 Read/Write)的权限。前者代表允许操作,而后者则是显式的拒绝。Obligation 表述的则是在策略匹配前后必须满足的条件或执行的操作,常用来进行对访问状态相关的属性动态更新^[14]。文献[15]用一个真实的多方共享资源的业务场景更加清晰阐述了 NGAC 的具体实施过程。

在实践中,人们还尝试融合 RBAC 和 ABAC^[16],充分发挥两种模型的优势,同时降低 ABAC 带来的复杂度。Aftab M U 等^[17]在基于物联网的交通控制领域进行了相关尝试,提出了安全的动态访问控制模型(SDAC, Secured Dynamic Access Control)。SDAC 引入了 ABAC 模型的思想,通过设置基于属性的角色,实现了角色的动态分配,有效的突破了 RBAC 中灵活性与扩展性不足的局面,同时又比 ABAC 更加直观,显著的降低了管理员的负担。

2.2 基于能力的访问控制

文献[18]在分析物联网的访问控制的解决方案时发现,基于能力的访问控制(CapBAC, Capability Based Access Control)在物联网领域也非常流行。能力通常通过令牌(Token)或者票据(Ticket)承载。由于没有携带令牌或者票据的访问请求一定会被拒绝, CapBAC 原生支持了完全仲裁原则(Complete mediation)。此外 CapBAC 在委派、离线授权等方面也有很好的支持。

文献[19]引入了基于属性的方法,实现了能力(权限)的细粒度控制,满足了最小权限(Least privilege)的需要。通过权限委派的形式,资源拥有者可以轻松配置资源的受访权限。被授权方与授权方的权威机构不需要建立复杂的信任关系,只要被授权方拥有令牌中指定的可供验证的属性即可。在这套访问控制机制下,管理访问控制变得简单许多。由于访问主体携带的令牌中包含了能力清单(Capability List),CapBAC支持无服务鉴权。受访对象不需要通过联系专门的策略决策点(PDP, Policy decision point)就可以完成授权。方便了连接不稳定的场景下进行访问控制。同样的,拥有令牌的主体,在授权允许的情况下,可以将自己的全部或部分能力(权限)委派给其它人。这种灵活的委派机制在多数物联网的应用场景中都受到欢迎。不过由于需要对受访对象(甚至属性)逐一确定配置能力(权限),在实际应用中,CapBAC对用户的操作要求仍然较高。

文献[20]进一步优化了这个方案。该文献作者将一定物理或逻辑区域内的,有着共同目标和任务的异构物联网设备群体定义为小区(Community),并将基于能力的访问控制扩展为以小区为对象的基于能力的访问控制(CoCapBAC, Community-driven Capability Based Access Control)。该方案化解了前述方案中权限配置时的易用性问题。方案采用了半分布式的部署形式,一个小区内的设备共享一个或多个PDP。这种部署形式,既避免了对单一的权威中心的依赖,也避免了完全分布的PDP部署带来的管理难题,同时更接近物联网的实际业务需求。

尽管基于能力的访问控制在物联网领域的应用场景中展示了不少优势,其基于令牌的授权方式必然要面对令牌的注销所带来的挑战,特别是在无服务鉴权等特殊场景下。这增加了基于能力的访问控制在实施时的复杂性^[18]。

2.3 软件定义安全

在企业信息网络中,一般采用边界防御与主机防护相结合的安全策略——尽管越来越多的案例表明,这种防御策略仍然不足以抵御包括高级持续性威胁(Advanced persistent threat, APT)在内的新型网络攻击。在物联网中,由于大量资源受限设备的存在,主机防护机制几乎无法实现。为了弥补这一缺失,访问控制需要具备对网络环境全局掌握的能力^[21,22]。文献[21]从物联网的三层架构出发,详尽的分析了在主要的物联网应用领域中各种方案与应用的安全需求以及面临的安全挑战之间的差距。文献的作者认为,从网络层入手解决物联网安全问题是弥补差距的最优途径。结合了基于软件定义的方法,在管理效率、动态能力、成本效益以及方案的适应性上都有巨大的提升,更能够增强抵御拒绝服务攻击(DoS, Denial

of Service)和 DDoS 攻击的能力。由于软件定义网络(SDN, Software defined network)已经具备了全局掌控、集中控制、分布部署等能力,且基于 OpenFlow 的开发已经成为 SDN 的事实标准,作者因此从安全视角上建议物联网应该深度融合 SDN。文献[22]的作者表示了相似的看法,并基于 SDN 架构提出了一套软件定义安全的方案。在方案原型中,作者展示了该方案对恶意软件注入、DDoS, 伪造攻击以及中间人攻击的防御能力。

SDN 的关键设计思想之一是解耦控制平面(Control Plane)与数据平面(也称转发平面, Data/Forward Plane)。云安全联盟(CSA, Cloud Security Alliance)提出的软件定义边界(SDP, Software Defined Perimeter)采用了相似的思想。SDP 被认为是零信任网络架构(ZTNA, Zero Trust Network Architecture)的实践方案之一。零信任的基础是实现最小权限原则(The Principle of Least Privilege)。最小权限原则是安全的基本原则之一,其核心思想是仅为访问主体分配完成其对客体访问操作所需的最少权限。在网络安全实践中,遵循最小权限原则意味着减少应用(或服务)在网络上的暴露,从而减少网络攻击面^[23]。SDP 以身份为中心,位于控制平面的 SDP 控制器(SDP Controller)进行统一的策略计算,而数据平面则通过策略执行点(Policy Execution Point)负责策略的执行。通过将访问控制的控制平面与数据平面分离,SDP 提供了架构上的灵活性和扩展性^[24],这与基于 SDN 的安全方案不谋而合。文献[25,26]分别提出并实现了一套相似的 SDP 的框架,后者特别针对 MQTT 协议设计,实现了在 SDP 保护下的 MQTT 订阅者(Subscriber)到 MQTT broker 的安全连接。两篇文献均验证了 SDP 具有缓解 DoS 攻击的能力,前者还展示了 SDP 的通过端口隐藏减小攻击面的能力。两篇文献也同时发现在部署了 SDP 的场景下,连接初始化会消耗更多的时间。文献[25]分析了时间消耗的主要操作包括:网关解密和验证单包认证(SPA, Single Packet Authentication),以及动态创建防火墙规则。因此,在时延敏感的业务场景中,SPA 的使用可能会带来风险。CSA 也就此给出了 SPA 的替代方案^[24]。

2.4 身份

SDP 宣称是以身份为中心的访问控制模型^[24]。事实上,无论采取何种访问控制方案,身份是一个不太容易绕过的因素。文献[15]在方案中明确了身份管理的模块,并使用用户名与口令的组合简单实现了主体身份认证的需要。文献[27]通过椭圆曲线加密(ECC, Elliptic Curve Cryptography)实现了轻量化的认证密钥协商,解决了智能表计(Smart meter)与高级计量系统(AMI, Advanced Metering

Infrastructure) 之间的双向认证问题。文献[22]则在基于 SDN 的安全方案中通过引用该方法, 实现了身份认证需要。其余方案中, 虽然没有明确负责身份认证的模块, 却都直接依赖身份或将其作为重要的属性进行策略评估^[9-11,19,20,25,26]。判断访问者的身份是访问控制系统的关键之一。但是在物联网的场景中, 基于单纯的标识信息进行设备身份认证的方式不完全适用。采用多种属性组合的方式, 可能比使用单个属性能够更好的识别设备^[8,28,29]。文献[30]通过收集主体的属性计算安全画像(profile), 作为对主体的持续信任评估机制。主体安全画像由一对统计值<D-st, Q-st>构成。任何一个值一旦超过了对应的控制上限(UCL, Upper control limit), 则认为主体可能处于不安全的状态, 相应的访问权限也随之吊销。由于画像的计算依赖大量从设备上采集的属性值, 其中包含大量的隐私信息。采用统计值来代表画像能够很好的保护设备的隐私。实际情况下, 当某台物联终端设备作为访问主体时, 它的各种访问行为可能会分别使用不同的身份。辨别设备背后的身份仍然是一项挑战^[8]。

2.5 小结

基于属性的方法具有扩展性、动态性和灵活性的优势, 但在实际研究中, 必须解决复杂度的问题。综合研究各种以属性为基础的访问控制模型后, 可以发现: 通过对属性集合的封装(包括但不限于: 角色、能力、关系等)能够有效的降低该方法带来的复杂度问题。

基于软件定义的思想, 解耦控制平面和数据平面能够在安全的基础上实现更好的动态性、灵活性和扩展能力。但以此为基础的访问控制方法, 特别是在物联网领域的研究还都处于早期阶段^[21]。

不论基于何种访问控制模型, 多数访问控制基于主体身份进行策略评估或获取策略评估所必须的属性。但是, 对于具有大量的异构设备的物联网场景, 不同设备主体身份的表达方式不尽相同。这种情况成为基于身份实施访问控制的一大挑战, 也制约了访问控制的扩展性。

物联网在建设与发展过程中, 网络层会持续承载不同的业务, 也面临不同形式的安全威胁。因此, 需要访问控制能够灵活的应对不同业务的安全需求。比如, 面对可能的恶意行为, 简单的丢包处置可能会影响连接甚至设备的稳定性, 文献[31]提出一种通过代理服务的形式将未授权(或非法)的访问转化为合法的“无效”访问的机制。又如, 尽管端到端加密技术可以保证数据传输的机密性和完整性, 但如果数据的接收端只是中转数据, 且运行在一个不可信的第三方平台中(比如在云上部

署的 Scada 服务器), 数据的所有者就有理由担心攻击者通过第三方平台窃取高度敏感的数据。为了应对这种威胁, 文献[32]提出了一种结合了代理重加密技术的细粒度访问控制方法, 保证了数据传输的机密性。

综上所述, 现有的访问控制模型或实现方法均有其局限性, 无法完全满足物联网的访问控制需求。特别是在面对海量异构设备带来的身份挑战和业务多样性带来的安全挑战, 现有的研究没有给出完整的解决方案。因此, 有必要从基于属性的方法出发, 遵循软件定义的路径, 并特别针对海量异构设备与应用多样性的问题深入研究访问控制。

第3章 研究内容及方案

3.1 基于设备画像的访问控制模型

3.1.1 问题描述

大多数访问控制模型在策略评估过程中依赖主体的身份。在电力物联网环境中，海量异构的设备接入使得如何统一地表述、管理和认证设备身份成为了挑战，也对访问控制策略的数量和复杂度造成影响。而策略的数量和复杂度则会影响访问控制的执行效率 and 管理的难度。由于通过对属性集合的封装能够有效的降低访问控制的复杂度，而利用属性集合亦有机会缓解访问控制对身份的依赖，因此，本研究拟通过构建设备画像代替设备身份，建立基于设备画像的访问控制模型。

3.1.2 拟采用的方法

设备画像定义为设备多种属性的集合。根据承载的业务不同，一台设备可能具备多套画像。访问控制策略亦是基于属性的。通过属性的关联，设备画像和访问控制策略匹配成为“画像-策略”模板（PrPoT, Profile-Policy Template）。当访问主体发起访问请求时，首先收集发出访问请求的设备、运行环境以及上下文等关键信息，形成设备设备画像的快照（Snapshot）；基于快照，动态查询“画像-策略”模板，完成认证（画像匹配）和授权（策略匹配）。图 2 展示的模式示意图描绘了该过程。

设计中访问控制模型将包含两个部分：一部分是注册，另一部分是评估。注册实际上是从设备画像初始化到“画像-策略”模板匹配的过程。本研究在设备注册过程中拟通过比对设备的基础属性和资产仓库的数据完成画像初始化，保证设备画像的真实性和准确性（如图 3）。在电力物联网中，由于多数物联终端设备的功能都非常有限（可以枚举），设备完成注册后即可生成画像。系统随即开始进行画像与策略的属性匹配，生成最终的“画像-策略”模板。如果推广至一般物联网的应用场景，面对功能更加复杂的物联终端设备，可以通过大数据结合人工智能的方法分析设备的行为属性，动态识别设备画像后再进行模板的匹配生成工作（不在本研究范围内）。评估过程就是生成快照并匹配“画像-策略”模板的过程。在这个过程中，认证与授权的过程同步完成。由于策略是与画像通过属性匹配，只有在最终生成的策略模板中才具有终端设备信息，因此，访问控制模型是设备无关的。管理员不需要为单一设备配置或维护访问控制策略。策略的复杂度预期会显著降低而策略评估效率会有提升。

由于所研究模型本质上是一种基于属性的方案，因此梳理并选择适当的属性集合作为画像是最为基础的工作。具体来说，就是以电力物联网的若干典型应用场景为研究对象，选出具有典型意义的设备静态属性（基本信息，如产品型号、厂商、MAC 地址和 IP 地址等）和动态属性（如访问请求、时间、位置等）的集合，以满足通过不同属性值的组合能够区分不同行为并作为画像加以认证的目标。本研究还包括通过属性集合定义设备画像的方法，生成“画像-策略”模板的方法，快照的获取方法以及通过快照匹配“画像-策略”模板的方法等。

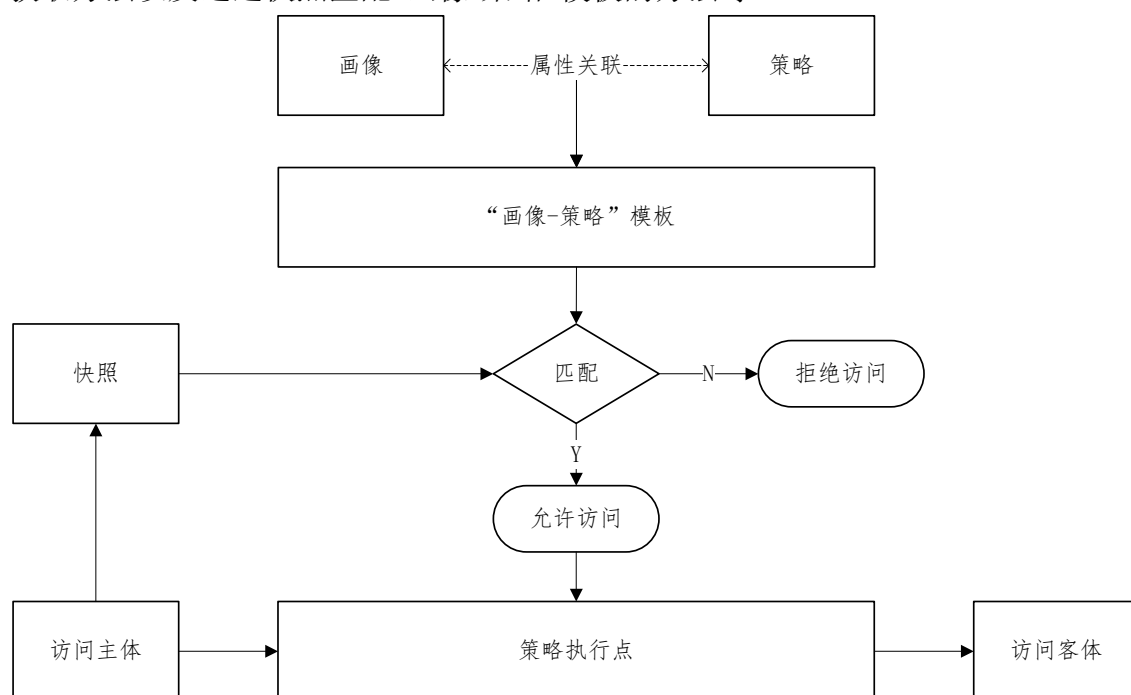


图 2. 预想的基于设备画像的访问控制模型

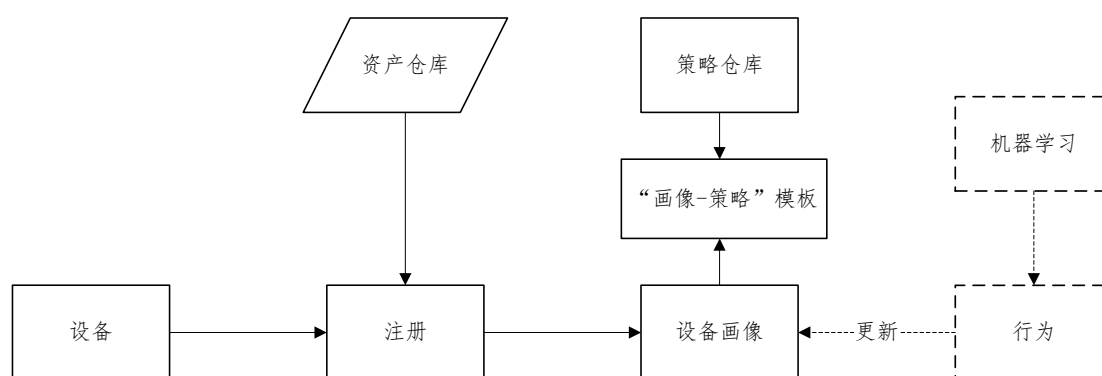


图 3. 预想的设备画像生成方法

3.1.3 研究进度及计划

本研究选取了一些设备的基本属性进行了可行性测试。后续包括属性梳理，策

略表达，匹配算法等研究工作待 3.2 节研究完成以后再行开展。表 1 是进行可行性测试时使用的 json 格式表达画像、策略以及“画像-策略”模板。

表 1. 测试时使用的画像、策略以及“画像-策略”模板 json 格式示意

画像	策略	画像-策略模板
<pre>{ "profile_4B1DDFM": { "mac_address": "9C-80-B5-59-56-56", "ip_address": "192.168.10.230", "local_gateway": { { "name": "gateway_7GBS3PKQ", "internal_ip": "192.168.10.1", "external_ip": "100.100.10.30" }, "serial_number": "20XWA005CD", "device_type": "Smart_Meter", "possible_targets": [{ "d_ip": "10.174.16.20", "d_port": "5000" }, { "d_ip": "10.174.16.28", "d_port": "5000,6000-6005" }, { "d_ip": "172.16.254.100", "d_port": "5000,5001" }] } } }</pre>	<pre>{ "server_policy_R0MU3B5F": { "10.174.16.20": { "ingress": [{ "ports": "5000", "device_type": "Smart_Meter", "gateway": { "name": "gateway_7GBS3PKQ", "internal_ip": "192.168.10.1", "external_ip": "100.100.10.30" }, "time_range": "0900-1000" }, { "ports": "8000", "device_type": "Workstation", "mac": ["0c:62:a6:9e:d4:23", "24:05:0f:b2:73:bc"] }], "egress": [{ "ip": "192.168.10.200", "port": "2404", "type": "FTU" }] } } }</pre>	<pre>{ "prpot-4B1DDFM-R0MU3B5F": { "mac_address": "9C-80-B5-59-56-56", "ip_address": "192.168.10.230", "local_gateway": { { "name": "gateway_7GBS3PKQ", "internal_ip": "192.168.10.1", "external_ip": "100.100.10.30" }, "device_type": "Smart_Meter", "target": { { "ip": "10.174.16.20", "ports": "5000" }, { "time_range": "0900-1000" } } } } }</pre>

3.2 云边协同的动态访问控制方法

3.2.1 问题描述

电力物联网一般都遵循“云管边端”的架构部署。云端与边缘的通信的安全通常由专网（有线专网或无线专网）或虚拟专用网络（VPN，Virtual Private Network）等安全通道辅以静态的访问控制策略保障。这种方式在实际应用中将面临两个安全风险：

- 1) 边缘节点通常部署在不可信的物理环境中，一旦边缘安全被突破，攻击者从边缘就可以利用通道对云端发起攻击。
- 2) 边缘的访问控制策略有可能得不到及时的维护或更新，造成云端策略与边缘策略无法匹配，更增大了系统被攻击的风险。

因此，本研究以电力物联网为研究对象，基于前项研究模型，拟提出一种访问控制实现方法：根据访问请求及环境条件等上下文属性动态地评估访问控制策略，

并分别下发至该请求所经过的各个访问控制节点，实现访问控制的云边协同执行。

3.2.2 拟采用的方法

本研究拟以软件定义的思想为基础，解耦访问控制控制平面和数据平面：控制平面包括认证引擎、策略引擎、通知引擎等模块负责访问控制的决策及结果下发；数据平面包括执行引擎，编排引擎等模块负责访问控制决策在各个执行点的执行。此外，跨越控制平面和数据平面的安全代理模块，负责两个平面间的消息与数据交互。根据前项研究中画像与快照的概念，设计中的访问控制过程可以分为：快照获取，画像与策略匹配，决策分发和决策执行（如图4）。

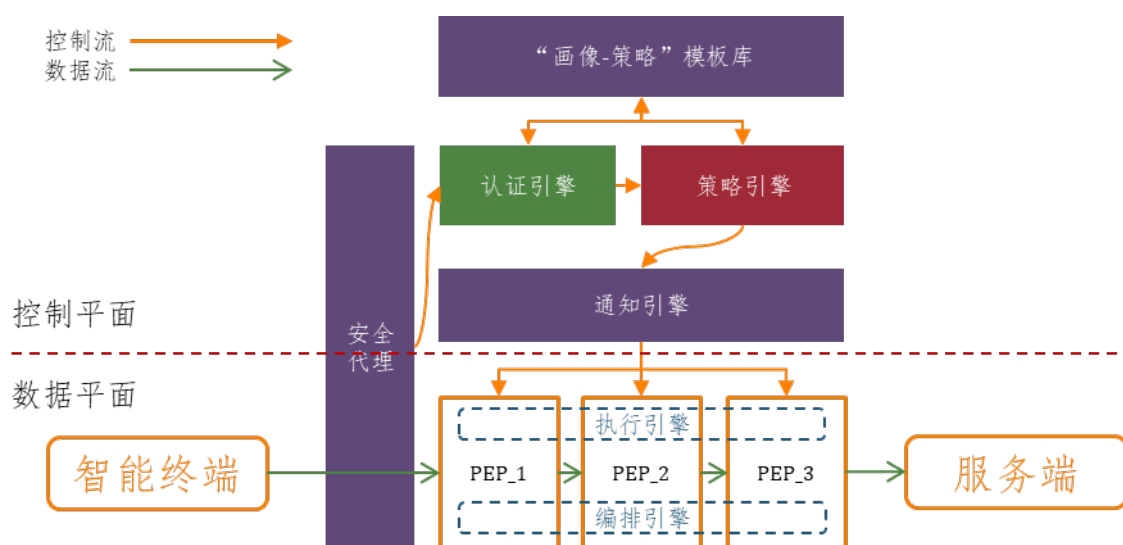


图4. 预想的访问控制模型

确定访问请求的“最小权限”是安全的基本原则之一。因此，需要收集访问请求中的主体、客体、所请求的动作，以及当前系统状态，运行环境等相关信息（即：快照），进行综合评判。设计中的安全代理模块负责收集、计算这些信息（即：生成快照）；并作为主体的唯一代表与控制平面进行通信以获取认证和授权。由于授权结果依赖实时收集并计算的信息，已经做出的授权不应该被缓存或重复使用，因此，在设计中要求每一个安全代理的工作进程应该是临时性的，按需生成且不可复用。并且，所有的请求都必须被授权，安全代理因此是不可绕过的。新的访问请求只有被安全代理模块检测并截获时，相应的安全代理工作进程才会生成；任何试图绕过安全代理的访问请求都将被丢弃以服从“完全仲裁”原则。

控制平面中的认证引擎和策略引擎模块的工作流程设计如图5。认证引擎负责明确快照中的主体和受访客体都具有合法的画像（或身份）；策略引擎根据“画像-策略”模板的匹配，完成授权并生成相应的执行规则。认证引擎和策略引擎共同完

成画像与策略匹配的工作，其输入和输出定义如表 2。通知引擎负责将访问控制决策分发至各个策略执行点。实现一次授权，多点执行的云边协同访问控制；满足安全需求同时兼顾了执行效率。

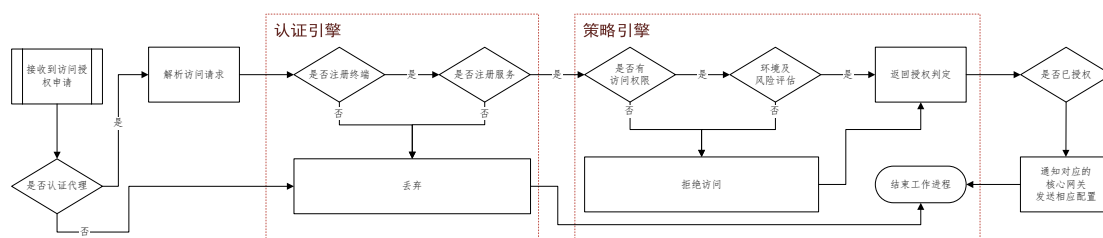


图 5. 预想的控制平面工作流程

表 2. 预想的画像与策略匹配过程的输入和输出内容定义

输入	设备画像快照（快照属性集合）
输出	1、相关策略执行点列表 2、所有策略执行点规则配置信息 3、编排配置信息：执行点，编排规则，内容检查规则

策略执行的动作在数据平面完成。设计中的执行引擎遵照控制平面下发规则进行相应的配置。根据策略引擎的输出，数据平面收到的访问控制规则后将分别在网络 OSI 三层、四层和七层（即网络层、传输层和应用层）分别执行（如图 6）。执行引擎将直接进行网络层和传输层的访问控制配置与执行；对于应用层的执行规则，执行引擎将通过调用编排引擎，基于预定义的编排剧本，调用不同的安全微服务执行。编排引擎的具体工作流程的研究将在 3.3 节中具体阐述。

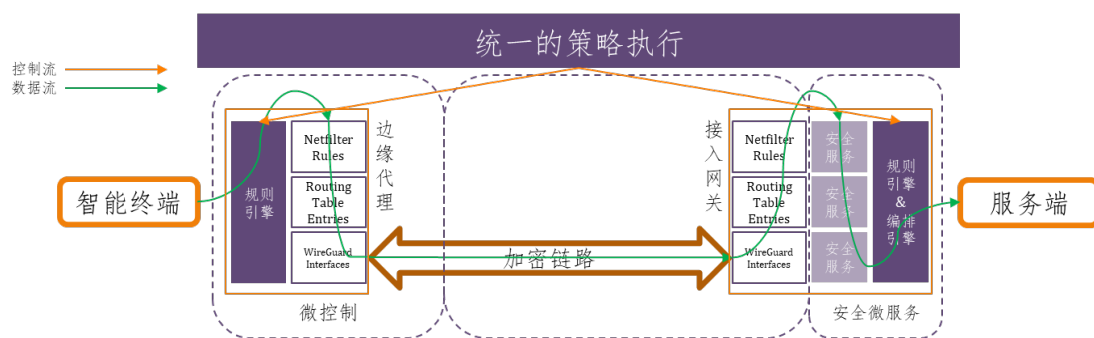


图 6. 预想的云边协同的数据平面工作流程

由于电力物联网中不仅含有从端点到云端服务的访问请求（如：MQTT 协议应用），也会包含云端应用向端点设备发出请求的场景（如：IEC60870-5-104 规约）；因此访问控制需要具备处理双向发起连接请求的能力。预计的访问控制流程如图 7。

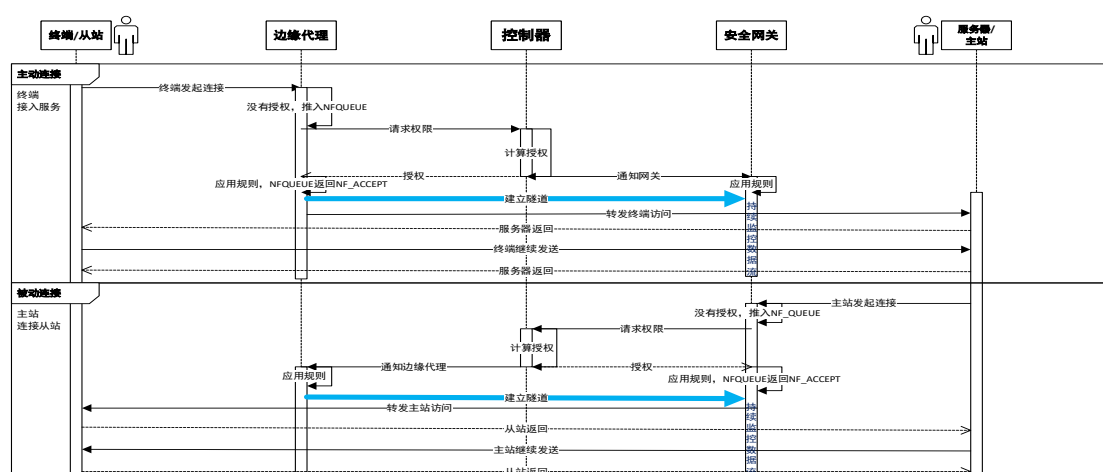


图 7. 预想的访问控制流程

3.2.3 研究进度及计划

本研究已完成基本的框架设计和部分模块的可行性测试。正在进行安全代理、认证和策略引擎、通知引擎、执行引擎等模块的具体设计。上述设计完成以后，将基于现有项目进行工程实现和优化，并使用常见的攻击手段（包括但不限于：DDoS攻击、中间人攻击、欺骗攻击以及重放攻击等）对工程实现进行安全测试。其中以满足工程需要为目标的设计与优化方法是本项研究的重点与难点。

3.3 基于编排的访问控制技术

3.3.1 问题描述

新业务的增加，需要引入新的访问控制策略或者访问控制装置。但由于 3.1.1 小节中描述的风险存在，添加新的访问控制策略过于复杂，通常难以实施。尽管后者会引入整体的停机时间，但由于相对前者可控，实际情况中反而会有机会采用。而在配置了多套的安全装置的场景下，业务性能也常会因为层层检查受到一定影响，特别是对时延敏感涉控业务影响较大。此外，部分物联网设备的协议健壮性较差，采用丢弃恶意网包等常规处置方案可能会造成设备网络连接中断，设备资源无法及时释放等问题。因此，有必要研究将访问控制分解为协议无关的安全能力，辅以编排技术以实现针对不同应用提供必要的业务层访问控制。

3.3.2 拟采用的方法

本研究拟引入微服务编排技术实现网络应用层访问控制需求。通过对网包检测能力和处置方法的梳理与抽象，构建一系列协议无关的安全微服务。数据平面的

编排引擎依据来自控制平面的决策，选择预定义的编排剧本，调用已经部署的安全微服务实现应用层访问控制（如图8）。

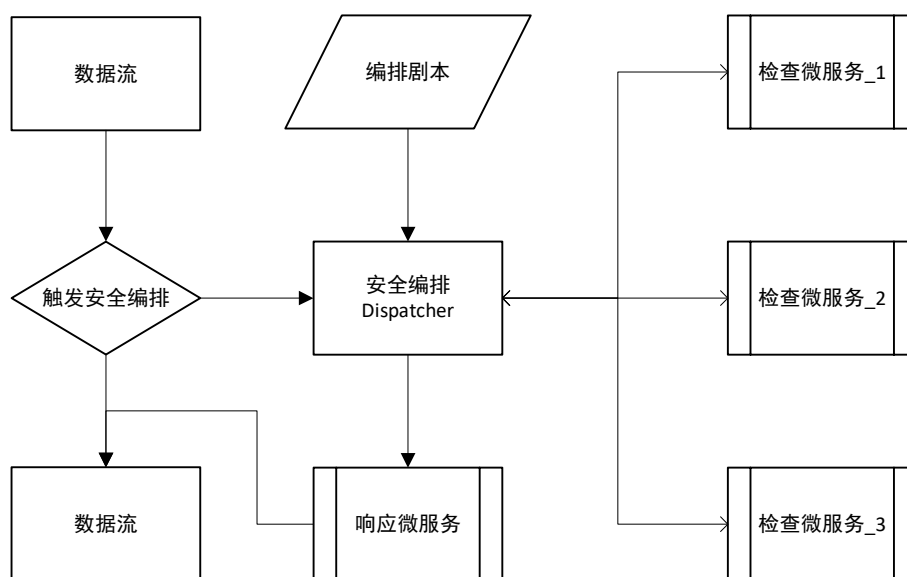


图8. 预想的安全微服务编排模型

安全微服务拟分为检查和响应两大类：检查类微服务负责对网包内容进行各类检查，响应类微服务负责依照决策对网包进行处置。典型的检查类微服务包括：协议解析、操作检查、访问对象检查、自定义字段检查、有效载荷检查等。响应类微服务应该支持允许通过、网包内容修改、网包内容过滤和中断连接等不同响应方案。比如：对于某 MQTT 协议应用，仅允许主体订阅（subscribe）特定的主题而不允许订阅非授权主题或者发布（publish）主题；对于某 IEC60870-5-104 应用，只允许进行遥信（AI）和遥测（DI）操作而不允许进行遥控（AO）或遥调（DO）操作。应对上述场景，对于 MQTT 的网包，需要编排协议解析、操作检查、访问对象检查，以及结果响应 4 种微服务（如图9）；而对于 IEC60870-5-104 应用，需要编排协议解析，操作检查，以及结果响应 3 种微服务（如图10）。对于 MQTT 应用，由于时延敏感度不高，可以采用双向 RESET 方式中断非法指令的连接（简单）；而对于 IEC60870-5-104 应用，由于其协议健壮性较差，应考虑将未授权的指令转换为合法的无效或空指令的处置方法（复杂）。

本研究的关键是将原本与协议紧耦合的网络应用层访问控制解耦为多个协议无关的安全微服务，通过编排剧本组合不同的基本能力实现应用层访问控制。上述两个实际应用场景将作为研究的切入点，重点验证其可行性。之后将对拆分的微服务模型进行抽象，并研究编排剧本的设计方法，使其更具通用性以便应用在更多场景中。最后通过在电力物联网的实际项目应用进行工程实现。

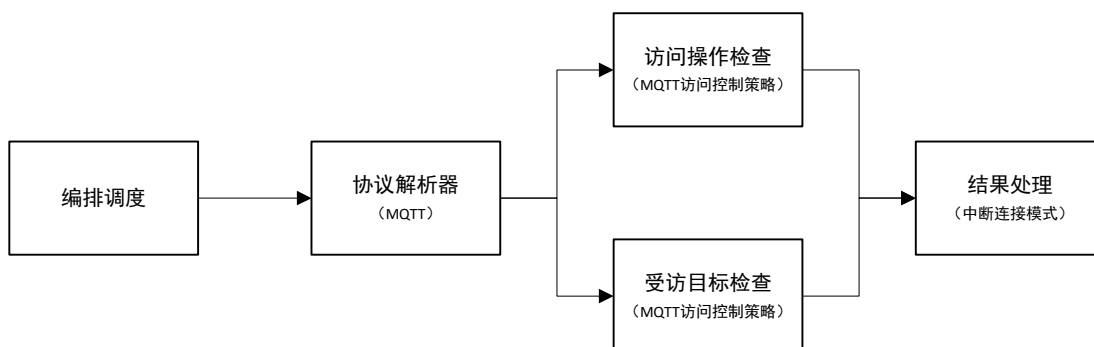


图 9. 适用于 MQTT 协议应用的编排示例

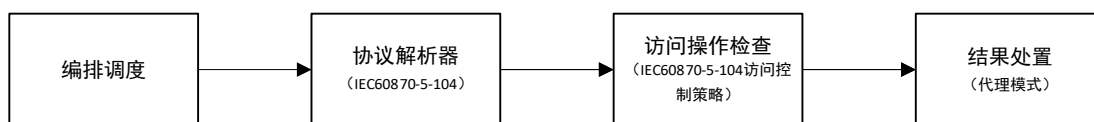


图 10. 适用于 IEC60870-5-104 应用的编排示例

3.3.3 研究进度及计划

本研究初步就 MQTT 应用和 IEC60870-5-104 应用的协议解析、内容检查和响应方式（结果处置）进行了可行性测试。后续工作待前两项研究内容完成后再行推进。

第4章 预期成果及创新点

本研究以电力物联网为研究对象，其预期成果为新型电力系统下的电力物联网提供一种新颖的安全接入及访问控制方案，并在部分电网项目上实际部署、实施和验证。部分研究成果和创新点可以推广到更多的物联网应用场景中。

本研究可能的创新点陈述如下：

- 1) **提出了一套设备无关的访问控制模型：**物联网环境中，海量异构设备的管理与访问控制始终是一项挑战。基于设备画像的访问控制模型通过引入设备画像，将访问控制策略与设备解耦。管理者在制定访问控制策略时，只需关注画像与权限的关系，而不必与具体设备挂钩。设备无关的访问控制能够提升访问控制的效率，同时简化管理者的负担，实现对异构设备的统一权限管理与访问控制。
- 2) **提出了一种访问控制云边协同动态执行的方法：**物联网环境中，一旦边缘环境被突破，攻击者便有可能攻击云端并造成重大的损失。而云边策略不匹配的情况更放大了这一风险。云边协同的动态访问控制方法，解耦访问控制的策略评估与决策执行：以控制平面统一管理策略，并对访问请求及环境条件等上下文属性动态地评估，以数据平面多点协同执行访问控制决策。提升了云边通信的安全能力兼顾了网络访问控制的执行效率。
- 3) **提出了协议无关的应用层安全能力编排技术：**一般情况下，不同的网络应用层协议对应不同的访问控制机制。为了承载多项业务，需要在网络上叠加不同的安全装置。基于编排的访问控制技术通过将网络应用层访问控制抽象为协议无关的安全能力，并通过微服务编排，满足不同业务在网络应用层访问控制需求。

以上创新点，将根据研究进度，申请专利或撰写论文。预计会形成相关论文两篇，专利两项。

第 5 章 论文工作总体安排

本研究课题的预计工作进度如下：

- ◆ 2021 年 9 月-2022 年 9 月，完成云边协同的动态访问控制方法相关研究，并完成相关原型设计，预期撰写相关论文一篇，申请相关专利一项。
- ◆ 2022 年 9 月-2023 年 3 月，完成基于设备画像的访问控制模型相关研究，并完成相关原型设计，预期申请相关专利一项。
- ◆ 2023 年 3 月-2023 年 12 月，完成基于编排的访问控制技术相关研究，并完成相关原型设计，预计撰写相关论文一篇。
- ◆ 2023 年 12 月-2024 年 6 月，整合研究成果，完成整体工程实现，并撰写博士毕业论文。

参考文献

- [1] Xenofontos C, Zografopoulos I, Konstantinou C, et al.Consumer, Commercial, and Industrial IoT (In)Security: Attack Taxonomy and Case Studies[J].IEEE Internet of Things Journal,2022, 9 (1): 199-221.
- [2] 汪洋, 苏斌, 赵宏波.电力物联网的理念和发展趋势[J].电信科学,2010, 26 (S3): 9-14.
- [3] 电力二次系统安全防护规定[J].中华人民共和国国务院公报,2005 (28): 34-36.
- [4] 刘林, 祁兵, 李彬, et al.面向电力物联网新业务的电力通信网需求及发展趋势[J].电网技术,2020, 44 (08): 3114-3130.
- [5] 张勋奎.以新能源为主体的新型电力系统发展路线图[J].分布式能源,2022, 6 (6): 1-8.
- [6] 江冰.构建面向 30 • 60 的新型电力系统——中国电力 4.0 的思考[J].全球能源互联网,2021, 4 (06): 534-541.
- [7] 陈皓勇, 李志豪, 陈永波, et al.基于 5G 的泛在电力物联网[J].电力系统保护与控制,2020, 48 (03): 1-8.
- [8] Bertin E, Hussein D, Sengul C, et al.Access control in the Internet of Things: a survey of existing approaches and open research questions[J].Annals of Telecommunications,2019, 74 (7-8): 375-388.
- [9] Khalil A, Mbarek N, Togni O. IoT-MAAC: Multiple Attribute Access Control for IoT environments[C].2020 IEEE 17th Annual Consumer Communications & Networking Conference (CCNC),2020: 1-6.
- [10] Bhatt S, Sandhu R. Abac-cc: Attribute-based access control and communication control for internet of things[C].Proceedings of the 25th ACM Symposium on Access Control Models and Technologies,2020: 203-212.
- [11] Bezawada B, Haefner K, Ray I. Securing home IoT environments with attribute-based access control[C].Proceedings of the Third ACM Workshop on Attribute-Based Access Control,2018: 43-53.
- [12] Atlam H F, Alassafi M O, Alenezi A, et al. XACML for Building Access Control Policies in Internet of Things[C].3rd International Conference on Internet of Things, Big Data and Security,2018: 253-260.
- [13] Ouaddah A, Mousannif H, Abou Elkalam A, et al.Access control in the Internet of Things: Big challenges and new opportunities[J].Computer Networks,2017, 112: 237-262.
- [14] Ferraiolo D, Chandramouli R, Hu V, et al.A comparison of attribute based access control (ABAC) standards for data service applications[J].NIST Special Publication,2016, 800: 178.
- [15] Bodin U, Christofferson A, Chiquito A, et al. Application-scoped Access Control for the Construction Industry[C].26th IEEE International Conference on Emerging Technologies and Factory Automation (ETFA 2021), Västerås, Sweden, September 7-10, 2021,2021: 1-8.

-
- [16] Thakare A, Lee E, Kumar A, et al. PARBAC: Priority-Attribute-Based RBAC Model for Azure IoT Cloud[J]. IEEE Internet of Things Journal, 2020, 7 (4): 2890-2900.
 - [17] Aftab M U, Oluwasanmi A, Alharbi A, et al. Secure and dynamic access control for the Internet of Things (IoT) based traffic system[J]. PeerJ Computer Science, 2021, 7: e471.
 - [18] Dramé-Maigné S, Laurent M, Castillo L, et al. Centralized, Distributed, and Everything in between: Reviewing Access Control Solutions for the IoT[J]. ACM Comput. Surv., 2021, 54 (7): Article 138.
 - [19] Gusmeroli S, Piccione S, Rotondi D. A capability-based security approach to manage access control in the Internet of Things[J]. Mathematical and Computer Modelling, 2013, 58 (5-6): 1189-1205.
 - [20] Hussein D, Bertin E, Frey V. A Community-Driven Access Control Approach in Distributed IoT Environments[J]. IEEE Communications Magazine, 2017, 55 (3): 146-153.
 - [21] Iqbal W, Abbas H, Daneshmand M, et al. An In-Depth Analysis of IoT Security Requirements, Challenges, and Their Countermeasures via Software-Defined Security[J]. IEEE Internet of Things Journal, 2020, 7 (10): 10250-10276.
 - [22] Karmakar K K, Varadharajan V, Nepal S, et al. SDN-Enabled Secure IoT Architecture[J]. IEEE Internet of Things Journal, 2021, 8 (8): 6549-6564.
 - [23] 李军, 胡效赫. 零触碰与零信任[J]. 中兴通讯技术, 2021: 1-9.
 - [24] Garbis J, Koilpillai J. Software-Defined Perimeter (SDP) Specification v2.0. <https://cloudsecurityalliance.org/artifacts/>: Cloud Security Alliance, 2022.
 - [25] Moubayed A, Refaey A, Shami A. Software-Defined Perimeter (SDP): State of the Art Secure Solution for Modern Networks[J]. IEEE Network, 2019, 33 (5): 226-233.
 - [26] Refaey A, Sallam A, Shami A. On IoT applications: a proposed SDP framework for MQTT[J]. Electronics Letters, 2019, 55 (22): 1201-1203.
 - [27] Mohammadali A, Sayad Haghighi M, Tadayon M H, et al. A Novel Identity-Based Key Establishment Method for Advanced Metering Infrastructure in Smart Grid[J]. IEEE Transactions on Smart Grid, 2018, 9 (4): 2834-2842.
 - [28] Hussein D, Bertin E, Frey V. Access control in IoT: From requirements to a candidate vision[C]. 2017 20th Conference on Innovations in Clouds, Internet and Networks (ICIN), 2017: 328-330.
 - [29] El-Hajj M, Fadlallah A, Chamoun M, et al. A Survey of Internet of Things (IoT) Authentication Schemes[J]. Sensors, 2019, 19 (5): 1141.
 - [30] García-Teodoro P, Camacho J, Maciá-Fernández G, et al. A novel zero-trust network access control scheme based on the security profile of devices and users[J]. Computer Networks, 2022, 212: 109068.
 - [31] Wei D, Darie F, Shen L. Application layer security proxy for smart Grid substation automation systems[C]. 2013 IEEE PES Innovative Smart Grid Technologies Conference (ISGT), 2013: 1-6.

- [32] Zhang W, Zhang H, Fang L, et al. A Secure Revocable Fine-Grained Access Control and Data Sharing Scheme for SCADA in IIoT Systems[J]. IEEE Internet of Things Journal, 2022, 9 (3): 1976-1984.